SESIÓN 3

Seguridad, Alta Disponibilidad y Diseño Arquitectónico

Maestría en Inteligencia Artificial Aplicada · BSG Institute

Capítulo 2 · Capítulo 3

TEMAS

T5

Seguridad y
Alta Disponibilidad

T6

Diseño y
Documentación

¿Qué aprenderemos hoy?

Dos temas que forman la base de un sistema LLM productivo y sostenible

T5 · Capítulo 2

Seguridad y Alta Disponibilidad

- 🔐 Autenticación JWT y OAuth2
- 🛡️ Autorización por scopes
- 🔥 Web Application Firewall (WAF)
- ⚡ Circuit Breaker Pattern
- 🔄 Replicación y Failover LLM
- 🏥 Health checks y Monitoreo
- 💾 Disaster Recovery (RTO/RPO)

T6 · Capítulo 3

Diseño y Documentación

- 📋 ADR (Architecture Decision Records)
- 🗺️ Modelo C4 (Context→Code)
- 📄 RFC: Request for Comments
- 📊 Análisis de costos TCO
- 📐 PRD: Product Requirements
- 💰 Sensibilidad y proyección 24m
- 📜 Documentación como código

Caso de Estudio

API LLM Empresarial — Sistema que construiremos durante la sesión

React Frontend
Vite 6 + JWT

FastAPI Backend
Auth + WAF

Ollama LLM
Local / Cloud

Audit Logger
SHA-256 Chain

CAPAS DE SEGURIDAD (T5)

- Rate Limiting
- WAF / Escaneo
- JWT Auth
- Scope Check
- Circuit Breaker
- Audit Log

ARTEFACTOS DE DOCUMENTACIÓN (T6)

- ADR
- RFC
- C4 Model
- PRD
- TCO Analysis
- Runbook

Objetivos de Aprendizaje

Al finalizar esta sesión, el estudiante será capaz de:

01 Implementar autenticación JWT con scopes y refresh tokens en una API productiva

02 Diseñar un WAF simulado capaz de detectar prompt injection, SQL injection y XSS

03 Aplicar el Circuit Breaker pattern para garantizar resiliencia ante fallos del LLM

04 Diseñar una estrategia de Disaster Recovery con RTO/RPO para sistemas de IA

05 Redactar ADRs y RFCs siguiendo los estándares de la industria tecnológica

06 Construir un modelo C4 completo (Context → Containers → Components → Code)

07 Calcular el TCO de 24 meses y realizar análisis de sensibilidad por proveedor LLM

CAPÍTULO 2

Tema 5

Seguridad y Alta Disponibilidad

JWT · OAuth2 | WAF | Circuit Breaker | Failover | DR / RTO·RPO

JSON Web Token (JWT)

Estándar RFC 7519 — Representación compacta de claims entre dos partes

ANATOMÍA DE UN JWT

HEADER . **PAYLOAD** . **SIGNATURE**

- HEADER: Algoritmo + tipo de token
- PAYLOAD: Claims: sub, exp, scopes, iat
- SIGNATURE: HMAC-SHA256 (Header + Payload + Secret)

OAUTH2 PASSWORD FLOW (RFC 6749 §4.3)

1. Usuario envía credenciales
2. Servidor valida password hash
3. Genera Access Token + Refresh Token
4. Cliente guarda token seguro
5. Cada request lleva Bearer token

Access Token: 30 min

Refresh Token: 7 días

Autorización por Scopes

Control de acceso granular — principio de mínimo privilegio

MODELO DE SCOPES DEL SISTEMA

Scope	Descripción	Endpoints permitidos	Usuario tipo
read	Consultar datos y chat	/api/chat, /api/health	Usuario básico
write	Modificar configuración	/api/chat, /api/config	Usuario avanzado
admin	Acceso total + auditoría	Todos + /api/audit	Administrador

ATAQUES COMUNES A JWT

Algorithm Confusion

Cambiar HS256→RS256 para bypass. Mitigación: fijar algoritmo en validación.

None Algorithm

Eliminar firma con alg:none. Mitigación: rechazar tokens sin firma.

Weak Secret

Fuerza bruta si el secret < 256 bits. Mitigación: secrets.token_hex(32).

Token Theft

Robo via XSS. Mitigación: httpOnly cookies + CSP headers.

Web Application Firewall (WAF)

Primera línea de defensa — filtra tráfico malicioso antes de que llegue al LLM



REGLAS WAF IMPLEMENTADAS

HIGH

Prompt Injection

"Ignore previous instructions..."

HIGH

SQL Injection

"'; DROP TABLE users; --"

MEDIUM

XSS

"<script>alert()</script>"

MEDIUM

Path Traversal

"../../etc/passwd"

LOW

Data Leakage

"sk-xxxx / Bearer token"

Circuit Breaker Pattern

Patrón de resiliencia que previene la cascada de fallos en sistemas distribuidos



PARÁMETROS DE CONFIGURACIÓN

failure_threshold	recovery_timeout	half_open_requests
5 Fallos para ABRIR	**30s** Tiempo en ABIERTO	**1** Requests de prueba

Alta Disponibilidad y Disaster Recovery

Garantizar continuidad del servicio ante fallos parciales o totales

CADENA DE FAILOVER LLM

1° Ollama (local)
0ms latencia
$0 costo

FAL ~~LO~~

2° Vertex AI (GCP)
Backup primario
SLA 99.9%

FAL ~~LO~~

3° OpenAI (fallback)
Último recurso
Pay-per-use

ESTRATEGIAS DE DISASTER RECOVERY

Estrategia	RTO	RPO	Costo	Uso recomendado
Backup & Restore	Horas	Horas	$	Dev / Test
Pilot Light	~10 min	Minutos	$$	No crítico
Warm Standby	~1 min	Segundos	$$$	Producción
Multi-site Active/Active	~0s	~0s	$$$$	Misión crítica

CAPÍTULO 3

Tema 6

Diseño y Documentación

ADR C4 Model RFC TCO PRD

Architecture Decision Records (ADR)

Registro inmutable del porqué de cada decisión arquitectónica importante

ESTRUCTURA DE UN ADR

Título	ADR-001: Usar JWT con scopes
Estado	Propuesto / Aceptado / Deprecado
Contexto	¿Por qué necesitamos decidir esto?
Decisión	"Usaremos JWT con scopes read/write/admin"
Consecuencias	Pros, contras, trade-offs
Criterios éxito	KPIs que validan la decisión

EJEMPLO: ADR-001 (fragmento)

```
# ADR-001: Autenticación JWT

Estado: Aceptado
Fecha: 2024-10-19

## Contexto
Necesitamos auth stateless para
una API con múltiples clientes.

## Decisión
Usaremos JWT HS256 con scopes
read, write y admin.

## Alternativas descartadas
• Sessions: requiere estado
• API Keys: sin expiración
```

Modelo C4 de Documentación Arquitectónica

4 niveles de zoom — desde negocio hasta código — para audiencias distintas

L1
Context

El sistema en su entorno de negocio

👥 CEO, Stakeholders

L2
Containers

Partes desplegables: API, DB, Frontend

👥 Arquitectos, DevOps

L3
Components

Módulos dentro de cada container

👥 Desarrolladores

L4
Code

Clases, funciones, diagramas UML

👥 Desarrolladores senior

↑ Más abstracto / negocio

Más técnico / código ↓

REGLA DE ORO DEL C4

- **Cada elemento** tiene nombre, tecnología y responsabilidad
- **Cada relación** muestra qué protocolo usa y qué comunica
- **L1 y L2** son obligatorios — L3 y L4 según complejidad
- **Una audiencia** por diagrama — no mezclar niveles

Análisis de Costos — TCO 24 Meses

Total Cost of Ownership — decisión estratégica, no solo técnica

COMPONENTES DEL TCO

Infraestructura

Cloud Run, GKE, Storage

LLM API

Tokens input/output por requests

Operaciones

Monitoreo, CI/CD, Soporte

Licencias

Herramientas, frameworks, SaaS

COMPARATIVA POR PROVEEDOR LLM — 50,000 req/mes · 800 tokens avg

Proveedor	Costo/mes tokens	Infra/mes	Total/mes	TCO 24m
Ollama (local)	$0	$120	$120	**$2,880**
Vertex AI	$82	$95	$177	**$4,248**
OpenAI GPT-4o	$240	$40	$280	**$6,720**

💡 Ollama reduce el TCO un 57% vs Vertex AI y 81% vs OpenAI para el mismo volumen de requests.

RFC y PRD — Gobernanza de Cambios

Dos artefactos complementarios para decisiones técnicas y de producto

RFC — Request for Comments

Propuesta técnica abierta a revisión del equipo

Resumen	¿Qué propone y por qué?
Motivación	Problema + evidencia (métricas)
Diseño	Solución técnica detallada
Trade-offs	Opciones A vs B vs No hacer
Implementación	Fases, estimados, rollback
Impacto	Rendimiento, costo, seguridad
Decisión	Aceptada / Rechazada + ADR

PRD — Product Requirements Doc

Define QUÉ construir, no CÓMO

P0 — **Must Have**
Sin esto no se lanza

P1 — **Should Have**
Importante pero no crítico

P2 — **Nice to Have**
Si queda tiempo

KPIs DEL SISTEMA

P99 latencia **< 2s**	Disponibilidad **≥ 99.9%**
WAF accuracy **< 1% FP**	Auth success **> 99%**

Resumen de la Sesión 3

Lo que construimos y hacia dónde vamos

✅ LO QUE VIMOS

- JWT con scopes + OAuth2 Password Flow
- WAF: 5 categorías de amenaza, regex patterns
- Circuit Breaker: 3 estados, asyncio.Lock
- Failover LLM: Ollama → Vertex → OpenAI
- DR: RTO/RPO, 4 estrategias
- ADR: registro inmutable de decisiones
- C4 Model: 4 niveles de zoom arquitectónico
- TCO 24m: Ollama 57% más barato que Vertex AI

PRÓXIMA SESIÓN

Sesión 4 — Producción y Observabilidad

T7	Deploy en producción (GKE + Terraform)
T8	Observabilidad: OpenTelemetry + Grafana
→	CI/CD con Cloud Build + Artifact Registry
→	SLO/SLA: error budgets y alertas

🧪 **Labs disponibles: make lab9 → lab14**

Repo: sesion3-seguridad-arquitectura-llm